How Our System Works

A plain-English guide to the firm's case-management system and client portal, and how we keep it safe.

1. The three parts

Think of the system as a well-run law office.

The reception desk
What people see and click: the staff screens and the client portal. It looks good, but it holds no secrets and makes no decisions.

Built with: Next.js

→

The security office
Every request comes here first. It checks who you are, what you're allowed to see, and writes everything in the logbook.

Built with: NestJS

→

The locked vault
Where client records, matters, money and documents are kept. Only the security office has the key.

Built with: PostgreSQL + private file storage

2. What happens when a client opens a document

1. The client logs in with their password **and** a code from their phone.
2. They click a document on the portal (the reception desk).
3. The request goes to the security office, which asks: *Is this really them? Is this their matter? Is this document shared with clients, or is it internal?*
4. Only if every answer is "yes" does the vault hand over the document, through a link that stops working after a few minutes.
5. The visit is written in the logbook, which no one can edit or erase.

> **If any answer is "no", the client gets nothing.** Hiding a button on the screen is never treated as security. The check always happens in the security office.

3. Who can see what

Information	Firm staff (with permission)	Clients
Their own matters and shared documents	Yes	Yes
Other clients or other matters	Only if assigned	Never
Internal notes and internal documents	Yes	Never
Money-laundering checks and risk notes	Compliance staff only	Never
Firm accounts and staff/HR records	Authorised staff only	Never

4. How a change gets built: our safety pipeline

Every improvement to the system, however small, goes through the same route before anyone can use it:

Change is written → Automatic checks → A person reviews it → Tried out with fake data → Goes live

The automatic checks run every time, and look for:

- **Mistakes:** does it still do what it should?
- **Break-in attempts:** do the tests prove a client *cannot* see someone else's file, even by trying tricks?
- **Leaked passwords:** has anyone accidentally left a password or key in the work?
- **Unsafe parts:** do any of the outside building blocks we use have known security holes?

> **If any safety check fails, the change stops.** It cannot go live until it is fixed. Nobody is allowed to switch a check off to get past it.

5. Our golden rules

- **Real client data never leaves the live system.** Building and testing only ever use made-up names and documents.
- **Everything important is logged:** logins, failed logins, document downloads, permission changes, money movements and approvals.
- **Client money and office money are kept apart.** Payments need approval, and the person who requests a payment cannot approve it. Mistakes are corrected with a new entry, never by deleting the old one.
- **Uploaded files are checked** for viruses and the correct file type before they are stored.
- **Data is stored encrypted and backed up**, with UK hosting planned.
- **Anything written by AI is only a draft** until a qualified person reads and approves it.

Version 1 · 3 October 2026 · The system is being built now. This guide describes how it is designed to work.